

CONFIDENTIAL — SECURITY ASSESSMENT

CYART

CYART Internal Security Assessment Report

N/A

Prepared By
CYART Offensive Security Team

Critical

OVERALL RISK

0

ASSETS

0

FINDINGS

1

CRITICAL

Table of Contents

1. Organization Details

2. Executive Summary

3. Scope

4. Methodology

5. Asset Inventory

6. Findings

7. Risk Matrix

8. Compliance Mapping

9. Recommendations

10. Appendix

11. References

1. Organization Details

Name: CYART

Industry: Cybersecurity

Website: <https://cyart.io>

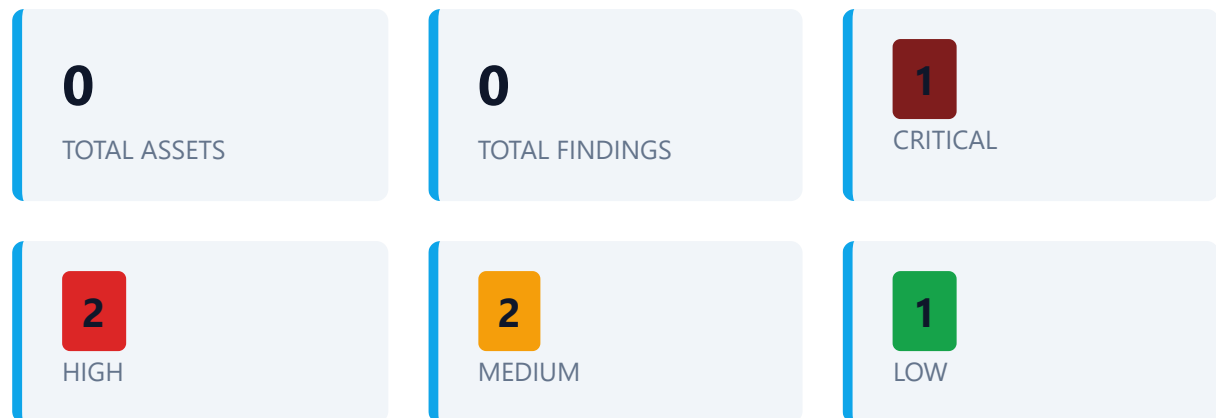
Email: security@cyart.io

2. Executive Summary

The assessment identified 1 Critical, 2 High, 2 Medium and 1 Low severity findings across 4 assets. The average CVSS score is 5.76. The overall organizational risk is

Critical.

Statistics



3. Scope

- assessment_name
- assessment_type
- target
- assessment_period
- assessment_team
- framework
- testing_type

4. Methodology

- Planning
- Reconnaissance
- Vulnerability Assessment
- Manual Validation
- Risk Analysis
- Reporting

5. Asset Inventory

Hostname	IP Address	Operating System	Status
WEB-PROD-01	192.168.1.10	Ubuntu 24.04	Active
DB-PROD-01	192.168.1.20	PostgreSQL 16 / Debian 12	Active
API-GW-01	192.168.1.30	Amazon Linux 2023	Active
LB-PROD-01	192.168.1.40	F5 BIG-IP 17.x	Active

6. Findings

SQL Injection in Authentication Endpoint

CRITICAL

CVSS: 9.8

DESCRIPTION

The /api/v1/login endpoint fails to sanitize the 'username' parameter, allowing an attacker to bypass authentication and extract arbitrary database records via boolean- and time-based blind SQL injection.

REMEDIATION

Use parameterized queries / prepared statements for all database access. Deploy a WAF rule as an interim compensating control and rotate any credentials that may have been exposed.

Outdated Apache HTTP Server Version

HIGH

CVSS: 8.7

DESCRIPTION

WEB-PROD-01 is running Apache 2.4.49, which is affected by publicly known path traversal and remote code execution vulnerabilities (CVE-2021-41773, CVE-2021-42013).

REMEDIATION

Upgrade Apache HTTP Server to the latest supported stable release and enable automated patch management for internet-facing hosts.

Excessive Database Privileges for Application User

HIGH

CVSS: 7.8

DESCRIPTION

The application's database service account has superuser privileges on DB-PROD-01, violating the principle of least privilege and increasing blast radius in the event of application compromise.

REMEDIATION

Create a dedicated least-privilege role scoped to only the schemas and operations the application requires; revoke superuser access.

Weak TLS Configuration

MEDIUM

CVSS: 5.6

DESCRIPTION

LB-PROD-01 accepts TLS 1.0 and TLS 1.1 connections and supports several weak cipher suites (e.g. RC4, 3DES).

REMEDIATION

Disable TLS 1.0/1.1 and weak cipher suites; enforce TLS 1.2+ with modern cipher preference ordering.

Missing Rate Limiting on API Gateway

MEDIUM

CVSS: 5.3

DESCRIPTION

API-GW-01 does not enforce per-client rate limiting on authentication and password-reset endpoints, enabling credential-stuffing and brute-force attacks.

REMEDIATION

Implement per-IP and per-account rate limiting with exponential backoff and CAPTCHA challenges on authentication endpoints.

Verbose Server Banner Disclosure

LOW

CVSS: 3.1

DESCRIPTION

HTTP response headers on WEB-PROD-01 disclose exact server software and version, aiding attacker reconnaissance.

REMEDIATION

Suppress or generalize Server/X-Powered-By headers.

Missing Security Headers

CVSS: 0.0

DESCRIPTION

Responses from WEB-PROD-01 lack Content-Security-Policy, X-Frame-Options, and X-Content-Type-Options headers.

REMEDIATION

Add standard hardening headers at the load balancer or application layer.

7. Risk Matrix

Critical	High	Medium	Low	Informational
0	0	0	0	0

8. Compliance Mapping

Framework	Control	Status
NIST CSF	PR.IP-12	
ISO 27001	A.12.6	

9. Recommendations

- {'priority': 1, 'title': 'Prevent SQL Injection', 'description': 'Use parameterized queries and input validation.'}
- {'priority': 2, 'title': 'Upgrade Apache', 'description': 'Upgrade Apache to the latest supported stable version.'}
- {'priority': 3, 'title': 'General Security Improvement', 'description': 'Review and remediate the identified vulnerability.'}
- {'priority': 4, 'title': 'Disable Weak TLS', 'description': 'Disable TLS 1.0 and TLS 1.1. Enable TLS 1.2 or higher.'}
- {'priority': 5, 'title': 'General Security Improvement', 'description': 'Review and remediate the identified vulnerability.'}
- {'priority': 6, 'title': 'General Security Improvement', 'description': 'Review and remediate the identified vulnerability.'}
- {'priority': 7, 'title': 'General Security Improvement', 'description': 'Review and remediate the identified vulnerability.'}

10. Appendix

- tools
- report_version
- classification

11. References

- OWASP Top 10
- NIST Cyber Security Framework
- MITRE ATT&CK
- CIS Controls

